

ZGB Native Additional Security Policies Evidence

Last updated: 2026-06-09

This packet supplies the additional Zoom Beta security documents requested in Technical Design: Security Policy, Incident Management and Response Policy, Vulnerability Management Procedure, and Infrastructure/Dependency Management Policy.

--- Security Policy ---
ZGB Native Security Policy

Last updated: 2026-06-05

Supported Version

The current review version is ZGB Native `0.1.0` build `1` for macOS 14.0 or later.

Data Protection

- ZGB Native stores queue content, saved session plans, recent broadcast records, and app configuration locally on the user's Mac.
- The production authorization flow does not persist OAuth access or refresh tokens inside the macOS app.
- Optional local OAuth backend mode on macOS stores Zoom OAuth tokens in the user's macOS Keychain. File-based token storage is reserved for local diagnostics only and is not used for production review builds.
- Secrets and tokens are excluded from source control, review packages, screenshots, documentation, support messages, and Marketplace comments.
- Broadcast messages are sent to Zoom meeting participants only when the user chooses to send them through the app.

Access Control

- Zoom meeting access depends on the user's Zoom authorization and meeting permissions.
- Breakout-room broadcast behavior requires the signed-in Zoom user to have the required Zoom host, co-host, administrator, or equivalent permissions.
- Local OAuth helper routes bind to `127.0.0.1` and are intended for local app use on the user's Mac.

Transport Security

- External Zoom OAuth, Zoom API, Zoom Meeting SDK, GitHub Pages documentation, and review download traffic use HTTPS.
- Public ZGB Native legal/documentation/OAuth redirect pages support TLS 1.2 or higher.
- Local loopback traffic between the app and backend may use `http://127.0.0.1` because it does not leave the user's Mac.

Secrets Management

- `.env`, `.env` backups, backend `.data`, OAuth tokens, client secrets, app packages, DerivedData, and provisioning profiles are excluded from GitHub.
- The backend deletes any legacy `Backend/.data/token.json` file when saving or clearing a Keychain token.
- Raw secrets must not be printed in logs, pasted into review forms, or sent in support messages.
- If a credential is suspected to be exposed, revoke or rotate it in Zoom Marketplace and invalidate locally stored tokens.

Monitoring and Logging

The current review build is a local macOS utility and does not operate a server-side production service for user data. Troubleshooting should use visible app errors, local backend health checks, and non-secret diagnostic details such as app version, macOS version, and endpoint status.

Contact

Use the developer contact email listed on the Zoom Marketplace app profile for security or privacy issues.

--- Incident Management and Response Policy ---

ZGB Native Incident Management and Response Policy

Last updated: 2026-05-29

Scope

This policy covers suspected or confirmed security incidents affecting ZGB Native, its local OAuth helper backend, public review/legal/documentation pages, review package distribution, or Zoom Marketplace configuration.

Incident Types

- Exposed OAuth client secret, Meeting SDK secret, OAuth token, refresh token, meeting passcode, or private credential.
- Unauthorized access to Zoom meeting functionality through the app.
- Review package containing unintended secret, token, local data, or private file.
- Vulnerability in the app or backend that could expose local data or misuse Zoom permissions.
- Public documentation, redirect, or download page compromise.

Response Process

1. Triage the report and identify affected version, account, file, endpoint, or package.
2. Contain the issue by removing exposed files, disabling public links, stopping affected local services, or revoking affected credentials.
3. Preserve minimum necessary evidence without copying raw secrets into tickets, chats, or public comments.
4. Eradicate the cause with code, configuration, packaging, or documentation changes.
5. Rotate or revoke affected Zoom credentials and invalidate local tokens when credential exposure is possible.
6. Verify the fix with targeted build, scan, DAST, TLS, package, or manual checks.
7. Document the incident, impact, timeline, fix, and follow-up actions.
8. Notify affected parties or platforms when required by law, platform policy, or reasonable security practice.

Severity Guidelines

- Critical: confirmed active exploitation, exposed production secrets, or unauthorized Zoom account access.
- High: likely credential exposure, package shipped with tokens/secrets, or vulnerability allowing unauthorized meeting actions.
- Medium: vulnerability requiring local access or unusual user action, or public page misconfiguration without secret exposure.
- Low: documentation gap, hardening opportunity, or non-exploitable scan finding.

Recovery

Recovery may include publishing a corrected package, updating public documentation, rotating Zoom Marketplace credentials, requiring users to reauthorize, or instructing users to delete local Keychain token items and any legacy local token files.

--- Vulnerability Management Procedure ---
ZGB Native Vulnerability Management Procedure

Last updated: 2026-05-29

Intake

Vulnerabilities may be identified through SAST, dependency audit, DAST, manual code review, user reports, Zoom Marketplace review, or developer testing.

Triage

Each finding is reviewed for:

- Affected component: macOS app, local backend, public page, review package, or Zoom Marketplace configuration.
- Exploitability and required access.
- Impact on secrets, OAuth tokens, meeting passcodes, local user data, Zoom authorization, or meeting actions.
- Whether the issue is already mitigated by local-only binding, user authorization, or Zoom platform controls.

Remediation Targets

- Critical: contain immediately and remediate before further distribution.
- High: remediate before release or Marketplace resubmission.
- Medium: remediate in the next practical update unless risk requires faster action.
- Low: track and fix opportunistically.

Verification

Fixes are verified with the relevant subset of:

- Xcode build/tests.
- `npm run check`.
- Semgrep SAST scan.
- `npm audit`.
- Local backend DAST smoke checks.
- TLS 1.2 handshake checks for public pages.
- Secret/package hygiene review.

Dependency Handling

Node dependencies are locked in `Backend/package-lock.json` and audited with `npm audit`. The current backend intentionally avoids third-party runtime npm dependencies. Zoom Meeting SDK updates are reviewed manually because the SDK is vendor-provided and not distributed through npm.

Tracking

Security findings, remediation decisions, scan artifacts, and verification notes are stored under `review/security/` or the project context file as appropriate.

--- Infrastructure and Dependency Management Policy ---
ZGB Native Infrastructure and Dependency Management Policy

Last updated: 2026-05-29

Architecture

ZGB Native consists of:

- A native macOS SwiftUI app.
- A local Node.js OAuth helper backend bound to `127.0.0.1`.
- Zoom OAuth, Zoom API, and Zoom Meeting SDK integrations.
- Public HTTPS GitHub Pages content for Privacy Policy, Terms of Use, documentation, and OAuth redirect forwarding.
- A public GitHub Release asset for the review ZIP.

ZGB Native does not operate a multi-tenant production backend for user data in the current review build.

Dependency Inventory

- macOS 14.0 or later.
- Xcode/Swift toolchain for native app builds.
- Node.js 20 or later for the local backend.
- Zoom macOS Meeting SDK vendor payload.
- GitHub Pages and GitHub Releases for public review/support artifacts.

Dependency Controls

- `Backend/package-lock.json` is retained for reproducible npm dependency auditing.
- `npm audit --omit=dev` is run for backend dependency vulnerability checks.
- The current backend has no third-party production npm dependencies.
- Vendor Zoom SDK payloads are excluded from GitHub and are handled as external vendor artifacts.
- App packages, DerivedData, `.env`, backend `.data`, OAuth tokens, and secrets are excluded from GitHub.

Infrastructure Controls

- Public pages are hosted over HTTPS and verified with HTTP status and TLS 1.2 checks.
- Public OAuth redirect pages forward the Zoom authorization query string to the local loopback backend and do not store tokens or secrets.
- Local backend routes are intended for the user's Mac and bind to `127.0.0.1`.

Change Management

Changes to OAuth redirect URLs, public review URLs, app packaging, dependency files, or Zoom SDK integration require documentation updates and targeted verification before Marketplace resubmission.